

SIMATS ENGINEERING ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

COURSE OUTCOME COVERED

***CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01

Total Marks:100

Annexure A **VULNERABILITY ASSESSMENT REPORT**

Code of Conduct:

*I **ch jaswanth(192372199)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

S.No .	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most	Identifies only basic or	Fails to identify important	
			major vulnerabilities with reasonable explanation.	obvious vulnerabilities.	vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and welljustified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	

5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable-use policies, and legal consequences.

VULNERABILITY ASSESSMENT REPORT

Annexure A — Answer Script | Case 1: TJX Companies Wireless Network Breach (2005–2007)

Course: Ethical Hacking (ITA1410) | CO4 | Assessment Tool 02

1. Incident Background and Technical Understanding

Between July 2005 and January 2007, TJX Companies — the parent corporation of retail chains such as T.J. Maxx, Marshalls, HomeGoods, and A.J. Wright — suffered what was, at the time, the largest payment-card data breach ever publicly disclosed. TJX operated thousands of retail stores across the United States, Canada, and the United Kingdom, each connected to central systems that processed credit-card and debit-card transactions, managed inventory, and synchronised customer data. The scale of the retail footprint meant that a single weakness at store level, if left unaddressed, had the potential to expose the entire corporate transaction-processing environment — and that is precisely what occurred.

The attackers' initial foothold was gained through the wireless local area network (WLAN) of a Marshalls store in Saint Paul, Minnesota. Investigators later determined that the store's wireless access points were still using Wired Equivalent Privacy (WEP) for encryption, even though the organisation was in the middle of a phased migration to the far stronger Wi-Fi Protected Access (WPA) standard. This meant that, for a significant window of time, a subset of TJX's retail locations were operating on a protocol that had already been shown by security researchers to be fundamentally broken. WEP's design flaws — short 24-bit initialisation vectors, weak RC4 key-scheduling, and predictable key reuse — allowed an attacker positioned within radio range of the store (for example, in an adjoining parking lot) to capture enough encrypted traffic and recover the WEP key using freely available cracking tools, often within a matter of minutes rather than hours.

Once the WEP key was recovered, the attackers effectively had the same level of network access as any legitimate wireless client in the store. From this vantage point they were able to observe network traffic, map out connected systems, and begin probing for a path toward more valuable targets. Because the wireless segment was not meaningfully isolated from the rest of TJX's infrastructure, the attackers were able to move laterally from the compromised store network into systems that handled and stored payment-card transaction data, including a legacy database that retained old transaction records containing full magnetic-stripe (Track 1 and Track 2) data — information that should never have been retained post-authorisation under card-brand rules. The attackers also installed sniffing software on TJX's network to continuously harvest new transaction data over an extended period, which meant the compromise was not a single smash-and-grab event but a sustained, long-running intrusion.

The breach went undetected for roughly eighteen months, from mid-2005 until it was finally discovered in December 2006 and publicly disclosed in January 2007. During that window, attackers are estimated to have accessed more than 45 million payment-card records (with some estimates running considerably higher once undetermined additional records are factored in), along with driver's licence numbers and other personal data collected in connection with merchandise returns. The prolonged dwell time reflects not only the initial wireless weakness but also a broader absence of monitoring, log correlation, and anomaly detection capable of flagging unusual data flows between the retail network and core systems. The TJX incident subsequently became a textbook case study — cited repeatedly in security literature and in the development of PCI DSS wireless-security requirements — of how a seemingly localised wireless weakness, when combined with a flat, poorly segmented network architecture, can cascade into an enterprise-wide breach of extraordinary scale.

Incident Snapshot

Attribute	Detail
Affected Organization	TJX Companies (T.J. Maxx, Marshalls, and related chains)

Timeline	July 2005 – January 2007 (discovered Dec 2006, disclosed Jan 2007)
Threat Actor	Organized cyber-criminal group (wireless / point-of-sale focused)
Wireless Technology Exploited	802.11 WLAN secured with WEP (during WPA migration)
Entry Point	Unsecured / weakly-encrypted store Wi-Fi access point
Primary Impact	Theft of 45M+ payment-card records

2. Identification of Wireless Vulnerabilities

A close technical review of the TJX incident reveals that the breach was not the result of a single isolated mistake but of several compounding weaknesses spanning encryption, authentication, network design, device management, data handling, and monitoring. Each of these is examined below.

- **Obsolete encryption standard (WEP):** The store WLAN relied on Wired Equivalent Privacy, a protocol whose cryptographic design had been publicly broken years earlier. Its 24-bit initialisation vector space is small enough that IV collisions occur quickly on a busy network, and its use of RC4 in a way that reuses key-stream material allows statistical key-recovery attacks. In practice this meant an attacker with commodity wireless hardware and open-source tools could recover the encryption key by passively capturing traffic for a short period, effectively rendering the 'encrypted' network no more secure than an open one.
- **Incomplete and prolonged WPA migration:** TJX had already begun transitioning to the stronger WPA standard, but the migration was not executed uniformly or urgently across all locations. This left a subset of stores — including the one ultimately exploited — running the legacy protocol for an extended period. A phased rollout without compensating controls (such as temporarily isolating or disabling WEP-only APs) effectively created a known, predictable weak link that persisted long enough for attackers to locate and exploit it.
- **Weak or absent authentication architecture:** Store access points appear to have used a shared, static pre-shared key model rather than per-user, per-device enterprise authentication. Under a pre-shared-key model, every device that knows the passphrase has equal access, there is no way to revoke a single compromised credential without changing the key for every legitimate device, and there is no individual accountability for who connected and when. The absence of 802.1X/EAP authentication backed by a centralised RADIUS server meant TJX had no mechanism to authenticate devices individually or to detect an unfamiliar device joining the network.
- **Poor network segmentation between retail Wi-Fi and payment systems:** Perhaps the most consequential architectural flaw was that the wireless network at store level was not meaningfully isolated — via VLANs, internal firewalls, or access-control lists — from the systems that processed and stored payment-card data. In a properly segmented design, compromising a store's guest or operational Wi-Fi should not, by itself, provide a path to core transaction-processing or database servers. At TJX, this segmentation was either absent or insufficiently enforced, allowing what began as a local wireless compromise to escalate into access over the wider corporate network.
- **Rogue and unmanaged access-point exposure:** With thousands of geographically dispersed stores, TJX's wireless infrastructure appears to have lacked centralized configuration management, meaning individual store access points could drift out of compliance with corporate security baselines without being flagged. There was no wireless intrusion detection system (WIDS) in place to identify rogue access points, unauthorized SSIDs, or access points broadcasting with outdated security settings.
- **Insecure handling and retention of cardholder data:** Beyond the wireless entry point, the environment reached by the attackers stored transaction data — including full magnetic-stripe track data — that should have been purged after authorisation under card-brand data-retention rules. This data was neither adequately encrypted at rest nor access-restricted to the degree required by the Payment Card Industry Data Security Standard (PCI DSS), turning what could have been a limited network intrusion into a large-scale data-theft event.
- **Insufficient monitoring, logging, and anomaly detection:** The intrusion persisted for roughly eighteen months without detection. This points to an absence of centralized log collection, correlation, and alerting capable of flagging unusual authentication patterns on the wireless network, unexpected lateral movement between network segments, or abnormal outbound data flows consistent with ongoing exfiltration. Without these controls, even a well-defended network can fail to notice a slow, patient attacker operating over an extended period.

3. Risk, Impact, and Root-Cause Analysis

Attack Vector and Root Cause

The root cause of the TJX breach was not a single failure but a chain of compounding weaknesses, each of which removed a layer of defence that should have contained the intrusion earlier. At the foundation was technical debt: the continued use of a deprecated, cryptographically broken encryption protocol (WEP) well past the point at which it should have been retired, driven by a slow and unevenly executed migration to WPA. Layered on top of that was an architectural failure — the absence of meaningful network segmentation between retail-store Wi-Fi and the systems responsible for processing and storing payment-card data, meaning there was no internal barrier to stop an attacker who had already breached the outer wireless perimeter. Compounding both of these was a governance and compliance gap: insufficient continuous monitoring against PCI DSS requirements, weak data-retention discipline that left obsolete but sensitive transaction data exposed, and an apparent lack of centralized oversight ensuring that security configurations were consistent across thousands of retail locations.

Reconstructing the attack as a chain makes clear how each stage depended on the failure of the one before it: (1) an attacker within radio range of a store identified a WLAN still secured with WEP; (2) the WEP key was recovered using standard cracking techniques, granting wireless network access; (3) because the wireless segment was not isolated from the wider corporate network, the attacker moved laterally toward systems handling transaction data; (4) weak data-retention practices meant historical records containing full track data were still present and accessible; and (5) sniffing software was installed to continuously harvest new transaction data, resulting in sustained exfiltration over many months. Because monitoring and alerting were insufficient at every one of these stages, the intrusion was allowed to run its full course rather than being interrupted early.

In terms of affected assets, the compromise reached far beyond the initial store-level access point: it ultimately touched customer-facing payment systems, back-end transaction databases, and archived records containing sensitive authentication data, illustrating how poorly bounded trust relationships between network zones can turn a narrow entry point into an enterprise-wide exposure.

Risk and Impact Summary

Impact Category	Description	Severity
Operational	Extended incident response, forced infrastructure overhaul, store-net	ork downtimeHigh
Financial	Estimated \$250M+ in breach-related costs, settlements, and upgrades	Critical
Privacy	Exposure of tens of millions of customers' payment-card details	Critical
Legal / Regulatory	State AG investigations, class-action lawsuits, PCI DSS non-complian	ce penaltiesHigh
Reputational	Loss of customer trust and brand damage across TJX retail chains	High

Each of these impact categories compounded the others rather than occurring in isolation. The **operational** impact included the cost and disruption of an emergency, enterprise-wide security overhaul: replacing wireless infrastructure, redesigning network segmentation, and engaging external forensic investigators, all while continuing day-to-day retail operations. The **financial** impact was severe and multi-layered, encompassing breach-notification costs, card-reissuance fees charged by issuing banks, settlements with state attorneys general and financial institutions, legal defence costs, and long-term security investment — collectively estimated at well over \$250 million. The **privacy** impact was significant in both scale and sensitivity, exposing tens of millions of customers to potential card fraud and identity-theft risk, with some records also including driver's-licence numbers collected during merchandise returns. The **legal and regulatory** impact included investigations by multiple state attorneys general, class-action lawsuits from affected consumers and financial institutions, and formal findings of PCI DSS non-compliance that drew scrutiny to the broader retail sector's wireless-security practices. Finally, the **reputational** impact was substantial and lasting: the breach became synonymous with poor wireless-security hygiene in retail, eroding consumer trust and prompting increased customer caution when using cards at TJX-owned stores.

Likelihood of recurrence without remediation was assessed as **High**. WEP-cracking tools are freely available, well-documented, and require minimal technical skill to operate, which keeps the barrier to exploitation very low. More importantly, the underlying architectural weakness — a flat network with no meaningful segmentation between wireless access and payment-processing systems — would continue to expose any newly connected wireless client, or any future weak access point, to the same lateral-movement path that the original attackers used. Without addressing the architecture itself, patching the encryption protocol alone would only close one of several open doors.

4. Security Recommendations and Mitigation Measures

The following recommendations are organised to directly address the vulnerabilities and root causes identified above, moving from immediate technical fixes to longer-term governance and cultural changes. Implemented together, they would close the specific chain of failures that enabled the TJX breach and reduce the likelihood of a similar wireless-originated compromise in the future.

- **Upgrade encryption immediately and completely:** Fully migrate every access point and client device across all store locations to WPA2-Enterprise at minimum, with WPA3 adopted wherever hardware supports it, and eliminate WEP entirely rather than allowing a prolonged or partial migration. A hard cut-over date, enforced centrally, prevents the kind of extended transition window that left TJX exposed.
- **Deploy enterprise-grade authentication:** Replace shared, static pre-shared keys with 802.1X/EAP authentication backed by a centralized RADIUS/AAA server, so that every device and user authenticates individually with revocable credentials. This provides accountability for who is connecting to the network and allows a single compromised credential to be revoked without having to change a passphrase shared across every device in a store.
- **Enforce strict network segmentation:** Place wireless networks, point-of-sale terminals, and back-office or transaction-processing systems on separate VLANs, with firewall and access-control-list rules enforcing least-privilege communication between segments. Even if a wireless segment is compromised in the future, this ensures the attacker cannot pivot directly into systems that handle or store cardholder data.
- **Implement rogue access-point detection:** Deploy a Wireless Intrusion Detection/Prevention System (WIDS/WIPS) capable of continuously scanning for unauthorized SSIDs, misconfigured or outdated access points, and anomalous wireless client behaviour across every retail location, with alerts routed to a central security operations function rather than left to individual store staff.
- **Align data handling with PCI DSS requirements:** Encrypt cardholder data both in transit and at rest, strictly minimise the retention of sensitive authentication data (never storing full magnetic-stripe track data post-authorisation), and schedule regular PCI DSS compliance audits, vulnerability scans, and penetration tests, treating compliance as a continuous process rather than a point-in-time certification.
- **Centralize configuration management:** Standardize access-point firmware, security settings, SSID naming, and key-rotation policy across all stores through a central wireless management console, removing the possibility of individual locations drifting out of compliance with corporate security baselines without detection.
- **Strengthen monitoring, logging, and correlation:** Centralize wireless and network logs into a Security Information and Event Management (SIEM) platform, with alerting tuned to flag anomalous authentication attempts, unexpected lateral movement between network segments, and unusual outbound data flows that could indicate ongoing exfiltration — closing the visibility gap that allowed the original intrusion to persist undetected for eighteen months.
- **Establish policy, training, and governance:** Publish and enforce a formal wireless-security policy covering approved hardware, minimum encryption and authentication standards, and key-management procedures, supported by periodic staff training so that store-level personnel understand their role in maintaining a secure network and can recognise and report suspicious activity.

5. Risk-Rating Summary

Vulnerability	Likelihood	Impact	Overall Risk Rating
Use of WEP encryption	High	Critical	Critical
Lack of network segmentation	High	Critical	Critical
Weak/shared authentication	Medium-High	High	High
Insufficient monitoring/WIDS	Medium	High	High
Non-compliant data handling (PCI DSS)	Medium	Critical	High

Conclusion

The TJX Companies breach remains one of the most instructive case studies in wireless network security precisely because it demonstrates how a single weak link, if left unaddressed, can cascade through an entire enterprise. What began as an outdated encryption protocol on a handful of retail access points ultimately resulted in the theft of tens of millions of payment-card records, hundreds of millions of dollars in direct and indirect costs, and lasting reputational damage. The incident underscores a broader lesson for any organisation operating distributed retail or branch-office wireless networks: security cannot rely on a single control. Strong encryption alone is not sufficient if authentication is weak; strong authentication alone is not sufficient if the network is flat and unsegmented; and even a well-segmented network is not sufficient without continuous monitoring capable of detecting the intrusions that inevitably slip through.

Addressing the root causes identified in this report — through enterprise-grade wireless authentication, strict network segmentation between retail Wi-Fi and payment-processing systems, centralized configuration and monitoring, and PCI DSS-aligned data handling and retention practices — would have substantially reduced both the likelihood of the initial compromise and the scale of impact had a breach still occurred. More broadly, the TJX incident directly influenced the tightening of PCI DSS wireless-security requirements industry-wide, serving as a cautionary example that continues to shape how retail organisations design and audit their wireless infrastructure today.

References

1. Privacy Rights Clearinghouse, "TJX Companies Data Breach" case summary.
2. U.S. Federal Trade Commission, In the Matter of The TJX Companies, Inc., File No. 072 3055.
3. PCI Security Standards Council, PCI DSS Requirements and Security Assessment Procedures.
4. NIST SP 800-97, "Establishing Wireless Robust Security Networks."